

RELAZIONE TECNICA DI LABORATORIO

Simulazione e Analisi di un Attacco DoS (UDP Flooding) in Ambiente Controllato

1. Obiettivo del Laboratorio

L'obiettivo di questa attività è analizzare il comportamento e la resilienza di un sistema legacy (**Windows XP**) a seguito di un attacco di tipo *Denial of Service* (**UDP Flooding**). Il test viene eseguito all'interno di un'infrastruttura di rete virtualizzata e segmentata tramite il firewall **pfSense**, al fine di isolare il traffico e documentare gli effetti del sovraccarico di pacchetti sulla CPU della macchina target.

2. Configurazione e Indirizzamento di Rete tramite pfSense

La topologia di rete è stata interamente configurata e gestita agendo sull'interfaccia di pfSense. La macchina target (Windows XP) è stata attestata sulla nuova interfaccia dedicata **OPT2** (associata alla rete interna **xpnet** su VirtualBox).

- Configurazione dell'Interfaccia:** Sulla console di pfSense è stata abilitata l'interfaccia **em0** (OPT2), assegnandole l'IP statico di gateway **192.168.100.1/24**.
- Assegnazione IP Statico a Windows XP:** Tramite la gestione della rete configurata su pfSense, è stato assegnato alla macchina Windows XP l'indirizzo IP statico **192.168.100.11**, garantendo il corretto instradamento dei pacchetti all'interno del laboratorio.
- Abilitazione Regole di Transito:** Nella WebGUI di pfSense sono state create le regole di *Pass* per consentire il transito bidirezionale dei pacchetti ICMP e UDP tra la rete di Kali (**192.168.10.0/24**) e quella di XP (**192.168.100.0/24**).

Dispositivo / VM	Interfaccia pfSense	Indirizzo IP	Subnet Mask	Ruolo / Note
pfSense 2.7.2	LAN (vtnet1)	192.168.10.1	255.255.255.0	Gateway di Kali
pfSense 2.7.2	OPT2 (em0)	192.168.100.1	255.255.255.0	Gateway di Windows XP
Kali Linux	LAN	192.168.10.11	255.255.255.0	Macchina Attaccante

Windows XP	OPT2	192.168.100.11	255.255.255.0	Macchina Vittima (Legacy)
------------	------	----------------	---------------	---------------------------

3. Fase 1: Reconnaissance (Information Gathering)

Una volta stabilita la connettività di rete, è stata effettuata una scansione delle porte sulla macchina target (192.168.100.11) tramite la macchina attaccante Kali Linux per identificare i servizi attivi ed esposti.

Strumenti utilizzati:

- Scansione delle porte principali con **Nmap**:

```

(kali@kali)~$ ping -c 4 192.168.100.11
PING 192.168.100.11 (192.168.100.11) 56(84) bytes of data:
64 bytes from 192.168.100.11: icmp_seq=1 ttl=127 time=0.952 ms
64 bytes from 192.168.100.11: icmp_seq=2 ttl=127 time=0.272 ms
64 bytes from 192.168.100.11: icmp_seq=3 ttl=127 time=1.29 ms
64 bytes from 192.168.100.11: icmp_seq=4 ttl=127 time=0.495 ms

--- 192.168.100.11 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 303ms
rtt min/avg/max/mdev = 0.272/0.777/1.300/0.366 ms

(kali@kali)~$ nmap -v -f 192.168.100.11
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 10:28 -0400
Nmap scan report for 192.168.100.11
Host is up (0.0025s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.78 seconds
(kali@kali)~$

```

Risultati riscontrati:

La scansione ha rivelato la presenza della porta **139 (NetBIOS-SSN)** aperta e attiva. Questa porta è stata selezionata come endpoint bersaglio per l'invio dei pacchetti di disturbo.

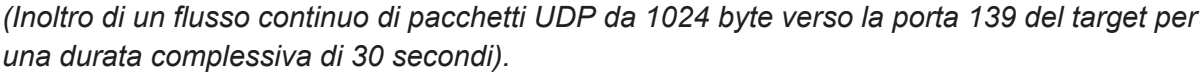
4. Fase 2: Analisi dello Script ed Esecuzione dell'Attacco

L'attacco è stato condotto tramite uno script personalizzato in **Python 3** (Dos.py).

Analisi del Codice Python:

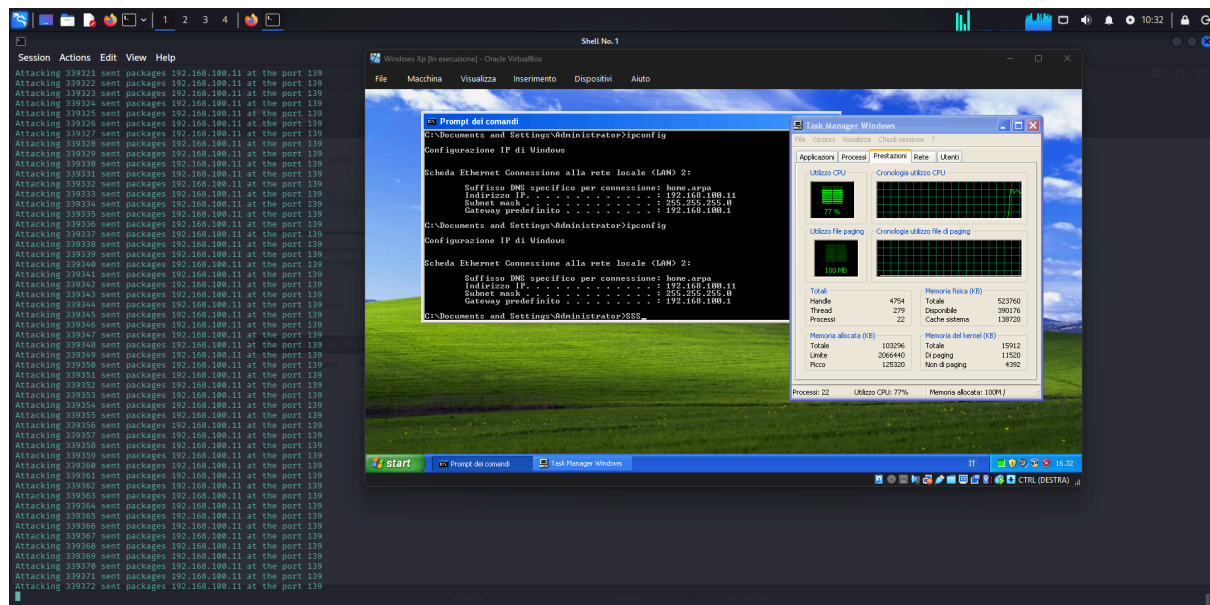
- **Meccanismo di trasporto:** Lo script istanzia un socket di tipo **SOCK_DGRAM** (protocollo **UDP**). A differenza di TCP, UDP è un protocollo *connectionless* (non orientato alla connessione): non richiede un handshake a tre vie, consentendo all'attaccante di inviare pacchetti in modo estremamente rapido senza attendere alcuna conferma di ricezione da parte dell'host di destinazione.
- **Payload generato:** Per massimizzare l'impatto sul canale di rete, lo script genera tramite la funzione **random._urandom(1024)** un array casuale di 1024 byte (pari a 1 KB di dati grezzi per pacchetto).
- **Ciclo di esecuzione:** Lo script avvia un ciclo **while** infinito controllato da un timer (**timeout = time.time() + duration**). Fino allo scadere del tempo impostato, lo script invia ininterrottamente i pacchetti sulla porta target tramite il metodo **client.sendto()**.

Comando avviato da terminale su Kali:



Durante l'esecuzione del flood (30 secondi), sono stati monitorati i parametri di sistema su Windows XP tramite il *Task Manager*:

1. **Saturazione della CPU:** L'utilizzo della CPU sulla macchina Windows XP è schizzato quasi al **100%**. Questo picco è dovuto al fatto che il sistema operativo deve dedicare l'interezza dei suoi cicli macchina per elaborare l'interrupt di rete e scartare la mole enorme di pacchetti UDP non richiesti in arrivo sul socket.
2. **Interruzione dei Servizi (DoS):** L'interfaccia grafica di XP è diventata quasi completamente inutilizzabile. Contemporaneamente, i tentativi di ping eseguiti da Kali durante l'attacco hanno registrato un tasso di caduta dei pacchetti (packet loss) del **100%**, provando la completa indisponibilità del target a processare traffico legittimo.



6. Considerazioni Finali e Mitigazione

L'efficacia di questa tipologia di attacco evidenzia la fragilità dei sistemi legacy quando esposti a traffico non filtrato.

Per mitigare attacchi di tipo UDP Flooding su **pfSense**, le configurazioni raccomandate includono:

- **Rate Limiting (Limitazione della frequenza):** Configurazione di regole specifiche nelle impostazioni avanzate del firewall per limitare il numero massimo di stati di connessione e pacchetti al secondo ammessi per singolo IP sorgente.
- **Chiusura preventiva dei servizi legacy:** Disattivazione totale dei servizi NetBIOS (porte 137-139) qualora non strettamente necessari alla produzione interna.